

# GUIA PRÁTICO DE SEGURANÇA DIGITAL

*Prevenção contra Golpes, Engenharia Social e Fraudes do Dia a Dia*

## Projeto de Extensão Universitária

Disciplina: Sistemas de Informação e Sociedade

**Acadêmico:** Diego Gimenez Silvino

**Matrícula:** 2024.06.03871-5

**Parceiro:** Comunidade Paroquial / Voluntários

## Apresentação e Objetivo

Este guia prático foi desenvolvido como intervenção extensionista de conscientização comunitária. O objetivo é capacitar voluntários, comerciantes e cidadãos a identificarem e neutralizarem vetores modernos de engenharia social, fraudes financeiras digitais (Pix) e ataques de quishing (QR Code malicioso), estabelecendo hábitos de proteção digital acessíveis e eficazes.

## Sumário

- O Fator Humano e a Engenharia Social
- Vetores Modernos: Quishing (QR Code Phishing)
- Análise Comparativa de Ameaças: Abordagem Fraudulenta vs. Protocolo de Resposta
- Diretrizes Operacionais para Tesouraria e Eventos Comunitários
- Checklist de Governança Digital Comunitária

## 1. O Fator Humano e a Engenharia Social

A engenharia social consiste na manipulação deliberada do comportamento humano, e não de sistemas técnicos, por meio da exploração de gatilhos psicológicos como urgência, medo, autoridade e oportunidade. O agente malicioso busca induzir decisões precipitadas antes que a vítima disponha de tempo para avaliar criticamente a situação.

### Estudo de Caso: Matriz de Cenário e Resposta a Incidentes — "Falso Parente"

|                                                                                                                                                                                                                                                            |                                                                                                                                                                                                                                                                                                      |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Etapa 1: Vetor de Contato</b><br>Recebimento de mensagem via aplicativo de mensageria, originada de número não cadastrado, alegando dano ao aparelho original.<br><i>"Oi mãe/pai, meu celular caiu na água e quebrou. Salva meu número provisório."</i> | <b>Etapa 2: Exploração de Urgência</b><br>Encaminhamento imediato de solicitação financeira, associada a prazo curto e justificativa de bloqueio bancário.<br><i>"Preciso pagar um boleto do curso agora e meu app do banco bloqueou. Faz esse Pix de R\$ 740 pra mim? Te devolvo hoje à noite!"</i> |
| <b>Etapa 3: Protocolo de Verificação</b><br>Antes de qualquer ação, o destinatário suspende a decisão e realiza contato de voz por linha telefônica previamente conhecida, a fim de confirmar a identidade do solicitante.                                 | <b>Etapa 4: Mitigação e Bloqueio</b><br>O contato original confirma a integridade do aparelho, evidenciando a tentativa de fraude. O número utilizado pelo agente malicioso é bloqueado e nenhum valor é transferido.                                                                                |

#### Recomendação Institucional

*Solicitações de transferência financeira originadas por mensagem de texto não devem ser atendidas sem confirmação prévia por chamada de voz ao contato previamente conhecido.*

## 2. Vetores Modernos: Quishing (QR Code Phishing)

Quishing é a modalidade de fraude em que códigos QR físicos — instalados em mesas, balcões de atendimento, postes e materiais impressos — são adulterados por agentes maliciosos, com o objetivo de redirecionar a vítima a páginas fraudulentas destinadas à captura de credenciais e dados pessoais.

### Estudo de Caso: Matriz de Cenário e Resposta a Incidentes — "QR Code Adulterado"

|                                                                                                                                                                                                                                                 |                                                                                                                                                                                                                                 |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Etapa 1: Vetor de Contato</b><br>Identificação de adesivo sobreposto ao QR Code original, disposto sobre o balcão de atendimento, associado a promessa de benefício.<br><i>"Escaneie aqui para ver o cardápio e ganhar 10% de desconto."</i> | <b>Etapa 2: Exploração de Urgência</b><br>Ao ser escaneado, o código direciona o usuário a uma página com layout idêntico ao de aplicativo de rede social, exigindo credenciais de acesso para validação do benefício ofertado. |
| <b>Etapa 3: Protocolo de Verificação</b><br>O usuário observa inconsistências no endereço eletrônico (URL) exibido na barra do navegador, identificando indícios de página clonada previamente à inserção de dados.                             | <b>Etapa 4: Mitigação e Bloqueio</b><br>A navegação é encerrada sem inserção de credenciais. O estabelecimento é notificado para remoção do adesivo fraudulento, preservando a integridade das contas dos demais usuários.      |

#### Alerta de Segurança

*O código QR constitui apenas um atalho de acesso a um endereço eletrônico. A verificação da barra de endereços do navegador é etapa obrigatória antes da inserção de senhas ou da execução de pagamentos.*

### 3. Análise Comparativa de Ameaças: Abordagem Fraudulenta vs. Protocolo de Resposta

A tabela a seguir sintetiza os principais vetores de fraude identificados no cotidiano, contrapondo a abordagem fraudulenta típica ao protocolo de resposta recomendado.

| Vetor / Canal                 | Abordagem Fraudulenta                                                                                                              | Protocolo de Resposta                                                                                                       |
|-------------------------------|------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------|
| <b>WhatsApp / Pix</b>         | Mensagem originada de número não cadastrado, solicitando transferência com urgência.                                               | Exigir confirmação por voz ou videochamada ao número previamente conhecido antes de qualquer transferência.                 |
| <b>Boleto / Cobrança</b>      | Documento (e-mail ou PDF) com cobrança urgente e dados do emissor divergentes dos registros oficiais.                              | Conferir o CNPJ e a razão social do beneficiário diretamente na tela do aplicativo bancário antes de confirmar o pagamento. |
| <b>Falso Suporte Bancário</b> | Contato telefônico de suposta central de segurança solicitando estorno de transação ou instalação de aplicativo de suporte remoto. | Encerrar a chamada imediatamente. Instituições financeiras não solicitam senhas ou transferências para reversão de fraudes. |
| <b>Balcão / Eventos</b>       | Apresentação de comprovante de Pix com status "agendado" como confirmação de pagamento.                                            | Autorizar a entrega apenas após confirmação do crédito no extrato oficial da conta.                                         |

#### Análise de Risco

*A engenharia social explora predominantemente o fator tempo e o estado de estresse do interlocutor. A suspensão da decisão por, no mínimo, 30 segundos neutraliza a maior parte das tentativas de fraude.*

## 4. Diretrizes Operacionais para Tesouraria e Eventos Comunitários

Voluntários e pequenos comércios responsáveis por recebimentos em eventos — festas comunitárias, quermesses e comércio local — devem observar diretrizes objetivas de controle interno, a fim de reduzir a exposição a fraudes financeiras durante o atendimento ao público.

### Diretrizes Aplicáveis

1. Conferência de transações Pix em tempo real diretamente no extrato bancário, com recusa de comprovantes estáticos ou de agendamentos.
2. Inspeção periódica de maquininhas de cartão quanto a visores danificados ou cobranças em valores divergentes do informado.
3. Segregação da rede Wi-Fi de uso interno em relação à rede disponibilizada ao público visitante.

### Fluxograma de Conciliação em 4 Etapas



#### Protocolo de Resguardo do Caixa

*Transações financeiras conduzidas em eventos comunitários demandam processos simples, padronizados e de aplicação rígida. O controle disciplinado do caixa constitui salvaguarda direta da arrecadação institucional.*

## 5. Checklist de Governança Digital Comunitária

O compartilhamento sistemático de boas práticas de segurança digital entre familiares, vizinhos e equipes de voluntários amplia a capacidade coletiva de prevenção. O checklist a seguir consolida os pontos essenciais tratados neste guia.

### CHECKLIST DE GOVERNANÇA DIGITAL COMUNITÁRIA

- ☐ Autenticação de Dois Fatores (2FA) ativada em aplicativos de mensageria e contas de correio eletrônico.
- ☐ Nome e CNPJ do beneficiário conferidos na tela do aplicativo bancário antes da confirmação final do Pix.
- ☐ Links de origem desconhecida, ofertas com prazo reduzido e promoções urgentes tratados com desconfiança.
- ☐ Códigos QR físicos inspecionados quanto a adesivos sobrepostos antes da leitura.
- ☐ Solicitações atípicas confirmadas por contato telefônico direto, previamente ao atendimento do pedido.

### Orientações Legais e Canais Oficiais de Denúncia

Em caso de fraude comprovada, recomenda-se o registro de boletim de ocorrência junto à Delegacia de Polícia Civil — preferencialmente em unidade especializada em crimes cibernéticos, quando disponível na localidade — e a comunicação imediata à instituição financeira envolvida para bloqueio e eventual reversão da operação. Reclamações relativas a instituições financeiras podem, adicionalmente, ser registradas junto ao Banco Central do Brasil e aos órgãos de defesa do consumidor (Procon), conforme a natureza da ocorrência.

*A segurança da informação constitui responsabilidade coletiva. Material desenvolvido para fins de extensão acadêmica, com foco em letramento digital comunitário e cidadania tecnológica.*